

حل الاختبار النهائي اختراق ويب (3)

حل الاختبار النهائي الشامل - دورة اختبار اختراق تطبيقات الويب

تم إعداد إجابات مختصرة وأكاديمية ومناسبة للاختبار.

المحاضرة 8 - XSS المتقدم

1. Input Filtering Output Encoding يمنع المدخلات الخطرة، أما
2. يمكن كسر سياق النص وإغلاق علامات التنصيص ثم حقن شيفرة جديدة.
3. تستخدم خصائص مثل onerror و onfocus لتنفيذ JavaScript دون الحاجة إلى script.
4. javascript: مباشرة عند الضغط على الرابط JavaScript يسمح بتنفيذ
5. يمكن استخدام Tab أو Newline أو الترميز بدلاً من المسافات.
6. يتم تنفيذ الشيفرة عبر onload داخل وسم SVG عند التحميل.
7. هي عملية اختيار الترميز المناسب حسب سياق الاستخدام لمنع XSS.

المحاضرة 9

1. تتم سرقة Session ID أو Cookie ثم استخدامها لانتحال هوية الضحية.
2. عبر تسجيل ضغطات لوحة المفاتيح وإرسالها للمهاجم.
3. باستخدام Webhook أو Burp Collaborator أو خادم استقبال HTTP.
4. عبر إنشاء صفحة تصيد داخل الموقع الموثوق.
5. JavaScript لا يمكن قراءتها مباشرة عبر HttpOnly.
6. عبر تعديل document.body.innerHTML واستبدال المحتوى.

المحاضرة 10

1. تستخدم ' لاختبار كسر الاستعلام وكشف الثغرة.
2. في PostgreSQL و -- في MySQL.
3. ORDER BY أسهل لتحديد عدد الأعمدة
4. من خلال رسائل الخطأ المميزة لكل قاعدة بيانات.
5. لإعادة إرسال الطلبات وتعديلها أثناء الاختبار.

المحاضرة 11

1. تحديد عدد الأعمدة، الأعمدة النصية، ثم استخراج البيانات.
2. بحقق قيم نصية وملاحظة ظهورها.
3. عبر information_schema.tables.
4. Oracle جدول وهمي في DUAL.
5. باستخدام CONCAT.
6. عبر (user) و (database).

المحاضرة 12

1. عند عدم ظهور البيانات مباشرة والاعتماد على الاستجابة أو الزمن.

2. SUBSTRING لمعرفة الطول LENGTH لاستخراج الأحرف و

3. لتسريع استخراج البيانات.

4. باستخدام SLEEP أو ما يعادلها.

5. بإجبار قاعدة البيانات على إظهار القيم ضمن الخطأ.

6. لأنها تكشف البيانات مباشرة.

المحاضرة 13

1. تستغل الثقة بين المتصفح والخادم.

2. صفحة HTML خبيثة وطلب مستهدف وضحية.

3. يمكن التحايل على Referer في بعض الحالات.

4. رمز عشوائي مرتبط بالجلسة.

5. XSS CSRF Token يمكنه قراءة أو استخدام

6. SameSite تمنع إرسال الكوكيز عبر الطلبات الخارجية

المحاضرة 14

1. XML يعرف الكيانات داخل DTD.

2. عبر كيان خارجي يشير للملف المطلوب.

3. عبر Billion Laughs لاستهلاك الموارد.

4. يستخدم OAST عندما لا يمكن رؤية النتائج مباشرة.

5. باستخدام php://filter.

المحاضرة 15

1. تغيير المعرف للوصول لبيانات مستخدم آخر.

2. تعديل معرف المستخدم في طلب تغيير كلمة المرور.

3. التحقق من الصلاحيات على الخادم.

4. لا يمنع الثغرة دون تحقق صلاحيات UUID

5. تعديل المعرفات في PUT و DELETE واختبار الوصول.